

AI Audit Report

1. API: FR-03 - Forgot Password (POST /api/forgot-password)

1.1 Stage 1 — Domain Partition — forgot-password

- **AI Tool:** Codex GPT-5
- **Date and Time:** 2026-08-22 23:32:18 +07
- **Your prompt:**

Với endpoint POST /api/forgot-password thuộc FR-03, đọc README.md và api_specification.md. Sinh domain partition test case cho tham số body `email` và header/body format liên quan: email hợp lệ đã đăng ký, email hợp lệ chưa đăng ký, email hoa/thường, email có whitespace đầu/cuối, thiếu email, email rỗng/null/whitespace, email sai format, sai kiểu dữ liệu, field thừa, và Content-Type không phải JSON. Trả về JSON array theo references/test_case_schema.md, category=DomainPartition.

- **The AI output:** Đã sinh 14 test case:
 - DP-01: Email đã đăng ký với định dạng hợp lệ nhận được OTP
 - DP-02: Email hợp lệ có chữ hoa/thường vẫn được nhận diện đúng user
 - DP-03: Email hợp lệ nhưng chưa đăng ký
 - DP-04: Thiếu field email trong body
 - DP-05: Email là chuỗi rỗng
 - DP-06: Email chỉ chứa khoảng trắng
 - DP-07: Email null
 - DP-08: Email sai định dạng thiếu domain
 - DP-09: Email sai định dạng không có ký tự @
 - DP-10: Email có khoảng trắng đầu/cuối
 - DP-11: Email có kiểu number
 - DP-12: Email có kiểu object
 - DP-13: Body có field thừa role
 - DP-14: Content-Type không phải JSON

Chi tiết đầy đủ tại [01_domain_partitions.json](#).

1.2 Stage 2 — State Transition — forgot-password

- **AI Tool:** Codex GPT-5
- **Date and Time:** 2026-08-22 23:33:36 +07
- **Your prompt:**

Với endpoint POST /api/forgot-password thuộc FR-03, phân tích state ẩn của vòng đời OTP cho email: chưa có OTP, đã có OTP, yêu cầu OTP lại, email chưa đăng ký, OTP đã dùng sau reset, và trạng thái bị rate-limit khi yêu cầu quá nhiều lần. Sinh test case JSON theo references/test_case_schema.md, category=StateTransition, có from_state, to_state, action, expected_allowed. Chỉ tập trung vào transition do endpoint request OTP gây ra; nếu cần kiểm chứng OTP cũ/hết hạn thì ghi trong preconditions/notes rằng cần phối hợp với POST /api/reset-password.

- **The AI output:** Đã sinh 6 test case:
 - ST-01: Email đã đăng ký từ trạng thái chưa có OTP chuyển sang có OTP hợp lệ
 - ST-02: Yêu cầu OTP lần hai cho cùng email thay thế OTP cũ
 - ST-03: Email chưa đăng ký không được chuyển sang trạng thái có OTP
 - ST-04: Request OTP không được làm mất quyền đăng nhập hiện tại của user
 - ST-05: Request OTP sau khi đã reset thành công tạo một OTP mới độc lập
 - ST-06: Request OTP quá nhiều lần trong thời gian ngắn bị giới hạn

Chi tiết đầy đủ tại [02_state_transitions.json](#).

1.3 Stage 3 — Security — forgot-password

- **AI Tool:** Codex GPT-5
- **Date and Time:** 2026-08-22 23:34:25 +07
- **Your prompt:**

Với endpoint POST /api/forgot-password thuộc FR-03, rà checklist SEC-01 đến SEC-07 trong references/security_requirements.md. Chọn các mục liên quan: SEC-07 cho entropy OTP, expiry/rate-limit và invalidation; SEC-05 cho SQL injection vào email; SEC-04 cho XSS/reflection qua email lỗi; SEC-02/SEC-03 để ghi rõ endpoint public và admin role không áp dụng trực tiếp; SEC-06 cho mass assignment field role/isAdmin bị bỏ qua; SEC-01 cho việc response không lộ password/hash. Bổ sung OWASP-Other cho user enumeration. Sinh JSON array theo references/test_case_schema.md, category=Security, có sec_id và attack_vector.

- **The AI output:** Đã sinh 11 test case:
 - SEC-01: OTP sinh ra phải có đúng 6 chữ số
 - SEC-02: Nhiều lần request OTP liên tiếp bị rate limit
 - SEC-03: SQL injection payload trong field email không gây bypass hoặc SQL error
 - SEC-04: SQL injection phá hoại trong field email không thực thi
 - SEC-05: Email chưa đăng ký không làm lộ trạng thái tồn tại tài khoản
 - SEC-06: XSS payload trong email không được phản chiếu như HTML thực thi
 - SEC-07: Endpoint forgot-password không yêu cầu JWT
 - SEC-08: Admin role check không áp dụng cho endpoint public forgot-password

- SEC-09: Mass assignment field role trong body bị bỏ qua
- SEC-10: Forgot-password response không được trả password hoặc password hash
- SEC-11: OTP mới không được trùng OTP liền trước cho cùng email

Chi tiết đầy đủ tại [03_security.json](#).

1.4 Stage 4 — Schema Validation — forgot-password

- **AI Tool:** Codex GPT-5
- **Date and Time:** 2026-08-22 23:35:34 +07
- **Your prompt:**

Với endpoint POST /api/forgot-password thuộc FR-03, đối chiếu response schema từ api_specification.md và README.md. Sinh schema validation test case cho response thành công 200 gồm message/resetToken, format resetToken là OTP 6 chữ số dạng string, không có field nhảy cảm/thừa, error response cho email sai format, thiếu email, email chưa đăng ký, và lỗi server không lộ chi tiết nội bộ. Trả về JSON array theo references/test_case_schema.md, category=SchemaValidation, có schema_ref và fields_checked.

- **The AI output:** Đã sinh 7 test case:
 - SV-01: Response thành công có đúng message và resetToken
 - SV-02: resetToken trong response thành công đúng format OTP 6 chữ số
 - SV-03: Response thành công không có field ngoài schema
 - SV-04: Response lỗi validation email sai format có cấu trúc lỗi chuẩn
 - SV-05: Response khi thiếu email có status và JSON error đúng
 - SV-06: Response email chưa đăng ký không lộ schema khác biệt quá mức
 - SV-07: Response lỗi server không lộ chi tiết nội bộ

Chi tiết đầy đủ tại [04_schema_validation.json](#).

2. API: FR-09 - Apply Coupon (POST /api/apply-coupon)

2.1 Stage 1 — Domain Partition — apply-coupon

- **AI Tool:** GPT-5 Codex
- **Date and Time:** 2026-08-23 01:03:00 +07
- **Your prompt:**

Hãy tạo test case cho Stage 1 – Domain Partitions với API được chọn là FR-09 `POST /api/apply-coupon`. Dựa trên `api\_specification.md`: endpoint nhận Body JSON gồm `code`, `total\_amount`, `user\_id`; mô tả là tính toán tổng tiền sau khi giảm và trả JSON chứa `discount\_amount` và `final\_amount`. Duyệt từng tham số body và header liên quan một cách có hệ thống: valid điển hình, valid

biên, invalid định dạng, invalid biên, thiếu field bắt buộc, field thừa/không mong đợi, sai kiểu dữ liệu, rỗng/null/whitespace. Không trộn logic bảo mật vào Stage 1. Trả về JSON array theo `references/test\_case\_schema.md`, mọi object có `category="DomainPartition"`, endpoint `POST /api/apply-coupon`, related_requirement `FR-09`.

- **The AI output:** Đã sinh 17 test case:
 - DP-01: Áp dụng mã coupon hợp lệ với tổng tiền đủ điều kiện
 - DP-02: Code hợp lệ có chữ thường cần được xử lý nhất quán
 - DP-03: Code không tồn tại trong hệ thống
 - DP-04: Thiếu field code trong body
 - DP-05: Code là chuỗi rỗng
 - DP-06: Code chỉ chứa khoảng trắng
 - DP-07: Code sai kiểu dữ liệu là number
 - DP-08: total_amount bằng 0
 - DP-09: total_amount là số âm
 - DP-10: total_amount là số dương rất nhỏ
 - DP-11: total_amount sai kiểu dữ liệu là string
 - DP-12: Thiếu field total_amount trong body
 - DP-13: user_id không tồn tại
 - DP-14: user_id sai kiểu dữ liệu là string
 - DP-15: Thiếu field user_id trong body
 - DP-16: Body có field thừa discount_amount do client gửi lên
 - DP-17: Content-Type không phải application/json

Chi tiết đầy đủ tại [01_domain_partitions.json](#).

2.2 Stage 2 — State Transition — apply-coupon

- **AI Tool:** GPT-5 Codex
- **Date and Time:** 2026-08-23 01:07:00 +07
- **Your prompt:**

Hãy tạo test case cho Stage 2 – State Transitions với API được chọn là FR-09 `POST /api/apply-coupon`. Dựa trên `api\_specification.md`: endpoint nhận Body JSON gồm `code`, `total\_amount`, `user\_id`, dùng để tính `discount\_amount` và `final\_amount`; spec quản lý coupon có các field liên quan state ẩn như `min\_order\_amount`, `expired\_at`, `max\_uses\_per\_user`, và có thao tác xóa coupon `DELETE /api/admin/coupons/:id`. Vì FR-09 không có state machine chính thức như order, hãy xác định state ẩn của coupon/user/order amount: coupon active, expired, deleted; order amount below/at/above minimum; user chưa dùng, đã dùng hết quota; user khác còn quota. Sinh test case JSON theo `references/test\_case\_schema.md`, `category="StateTransition"`, có đủ `from\_state`, `to\_state`, `action`, `expected\_allowed`, bao gồm cả chuyển trạng thái hợp lệ và không hợp lệ. Không trộn logic security vào Stage 2.

- **The AI output:** Đã sinh 8 test case:
 - ST-01: Coupon còn hiệu lực chuyển từ chưa áp dụng sang đã áp dụng
 - ST-02: Coupon hết hạn không được chuyển sang trạng thái đã áp dụng
 - ST-03: Coupon đã bị xóa không được áp dụng
 - ST-04: Đơn hàng chưa đạt min_order_amount không được áp dụng coupon
 - ST-05: Đơn hàng vừa đạt min_order_amount được áp dụng coupon
 - ST-06: User đã dùng hết max_uses_per_user không được áp dụng lại coupon
 - ST-07: User khác vẫn được áp dụng coupon khi quota của chính họ còn
 - ST-08: Coupon vừa hết hạn sau một lần áp dụng thành công không được áp dụng tiếp

Chi tiết đầy đủ tại [02_state_transitions.json](#).

2.3 Stage 3 — Security — apply-coupon

- **AI Tool:** GPT-5 Codex
- **Date and Time:** 2026-08-23 01:09:00 +07
- **Your prompt:**

Hãy tạo test case cho Stage 3 – Security với API được chọn là FR-09 `POST /api/apply-coupon`. Dựa trên `api\_specification.md`: endpoint nhận Body JSON gồm `code`, `total\_amount`, `user\_id`, dùng để tính `discount\_amount` và `final\_amount`; spec không ghi rõ Authorization cho endpoint này, nhưng coupon có trạng thái/giới hạn theo user và có các field quản lý như `min\_order\_amount`, `expired\_at`, `max\_uses\_per\_user`. Rà checklist SEC-01 đến SEC-07 theo `references/security\_requirements.md`: SEC-01 kiểm gián tiếp response không rò rỉ password/hash; SEC-02 kiểm broken auth/JWT và user_id mismatch vì endpoint tác động quota/giảm giá theo user; SEC-03 không áp dụng trực tiếp vì không phải admin API; SEC-04 kiểm XSS payload trong code nếu message echo ra UI; SEC-05 kiểm SQL injection vào code; SEC-06 không áp dụng trực tiếp vì không phải update profile nhưng cần xét mass assignment/parameter tampering tương đương; SEC-07 không áp dụng vì không liên quan OTP. Bổ sung OWASP-Other cho IDOR, parameter tampering, business logic abuse, rate limiting. Sinh JSON array theo `references/test\_case\_schema.md`, `category="Security"`, có `sec\_id` và `attack\_vector` rõ ràng cho từng case.

- **The AI output:** Đã sinh 10 test case:
 - SEC-01: SQL injection payload trong field code không được làm bypass coupon lookup
 - SEC-02: SQL injection destructive payload trong code không được gây lỗi DB hoặc thay đổi dữ liệu
 - SEC-03: Không cho client tự áp dụng coupon cho user_id khác khi không có JWT
 - SEC-04: Token hợp lệ của user này không được áp dụng coupon thay cho user khác
 - SEC-05: Client không được tự gửi discount_amount để tăng mức giảm
 - SEC-06: Client không được tự gửi final_amount để thao túng tổng tiền cuối
 - SEC-07: Không cho dùng total_amount giả lớn hơn giỏ hàng thật để đạt min_order_amount
 - SEC-08: Rate limit khi brute-force nhiều coupon code

- SEC-09: Response apply-coupon không được rò rỉ password hoặc passwordHash của user
- SEC-10: XSS payload trong code không được phản hồi như HTML thực thi được

Chi tiết đầy đủ tại [03_security.json](#).

2.4 Stage 4 — Schema Validation — apply-coupon

- **AI Tool:** GPT-5 Codex
- **Date and Time:** 2026-08-23 01:11:00 +07
- **Your prompt:**

Hãy tạo test case cho Stage 4 – Schema Validation với API được chọn là FR-09 `POST /api/apply-coupon`. Dựa trên `api\_specification.md`: endpoint nhận Body JSON gồm `code`, `total\_amount`, `user\_id`; response thành công phải là JSON chứa `discount\_amount` và `final\_amount`. Đối chiếu hình dạng response với spec, không kiểm sâu business logic: response 2xx phải có đủ field bắt buộc, đúng kiểu dữ liệu number, không thiếu/không thừa field không được mô tả, giữ invariant `final\_amount = total\_amount - discount\_amount`; response lỗi cho coupon không tồn tại, thiếu field bắt buộc, sai kiểu dữ liệu phải có JSON error schema ổn định và không trả stack trace/HTML/field success. Kiểm tra thêm response không lộ password/passwordHash/token nội bộ. Sinh JSON array theo `references/test\_case\_schema.md`, `category="SchemaValidation"`, có `schema\_ref` và `fields\_checked` rõ ràng.

- **The AI output:** Đã sinh 7 test case:
 - SV-01: Response thành công phải có đủ discount_amount và final_amount
 - SV-02: discount_amount và final_amount phải là number
 - SV-03: final_amount phải khớp công thức total_amount - discount_amount
 - SV-04: Response thành công không trả thừa object coupon hoặc user
 - SV-05: Coupon không tồn tại trả error schema, không trả success schema
 - SV-06: Thiếu field code trả lỗi validation có message rõ ràng
 - SV-07: Sai kiểu total_amount trả lỗi validation JSON ổn định

Chi tiết đầy đủ tại [04_schema_validation.json](#).

3. API: FR-17 - Admin Coupons (POST /api/admin/coupons)

3.1 Stage 1 - Domain Partition - admin-coupons

- **AI Tool:** Codex (GPT-5)
- **Date and Time:** 2026-08-23 02:13:17 +07
- **Your prompt:**

Với endpoint FR-17 `POST /api/admin/coupons`, dựa trên spec body gồm `code`, `type`, `discount\_value`, `min\_order\_amount`, `expired\_at`, `max\_uses\_per\_user` và yêu cầu admin JWT. Sinh domain partition test case cho từng tham số: valid điển hình, valid boundary, invalid format, invalid boundary, thiếu field bắt buộc, field thừa, sai kiểu dữ liệu, rỗng/null/whitespace. Không trộn SQLi/XSS/JWT/role security vào stage này. Trả về JSON array theo `test\_case\_schema.md`, `category=DomainPartition`, ghi rõ request, expected status/result, priority, parameter và partition_type.

- **The AI output:** Đã sinh 15 test case:
 - DP-01: Tạo coupon percent hợp lệ với đầy đủ field bắt buộc
 - DP-02: Tạo coupon fixed amount hợp lệ
 - DP-03: Tạo coupon percent với discount_value biên nhỏ nhất hợp lệ là 1
 - DP-04: Tạo coupon percent với discount_value biên trên hợp lệ là 100
 - DP-05: Thiếu field code khi tạo coupon
 - DP-06: Code rỗng hoặc chỉ có khoảng trắng
 - DP-07: Code bị trùng với coupon đã tồn tại
 - DP-08: Type nằm ngoài enum hợp lệ
 - DP-09: discount_value bằng 0 cho coupon percent
 - DP-10: discount_value lớn hơn 100 cho coupon percent
 - DP-11: discount_value sai kiểu dữ liệu là chuỗi
 - DP-12: min_order_amount âm
 - DP-13: expired_at sai định dạng ngày
 - DP-14: max_uses_per_user bằng 0
 - DP-15: Body có field thừa is_active khi tạo coupon

Chi tiết đầy đủ tại [01_domain_partitions.json](#).

3.2 Stage 2 - State Transition - admin-coupons

- **AI Tool:** Codex (GPT-5)
- **Date and Time:** 2026-08-23 02:14:03 +07
- **Your prompt:**

Với FR-17 quản lý mã giảm giá, spec không có state machine order nhưng coupon có state nghiệp vụ ẩn: non-existent, active, duplicate-created, deleted, expired, unused/used-by-user/used-beyond-limit. Sinh state transition test case cho `POST /api/admin/coupons`, `DELETE /api/admin/coupons/:id` và chỉ dùng `POST /api/apply-coupon` khi cần quan sát trạng thái sử dụng coupon. Mỗi case phải có from_state, to_state, action, expected_allowed theo `test\_case\_schema.md`, `category=StateTransition`.

- **The AI output:** Đã sinh 8 test case:

- ST-01: Tạo coupon mới chuyển từ non-existent sang active
- ST-02: Tạo lại coupon đã active bị từ chối duplicate
- ST-03: Xóa coupon active chuyển sang deleted
- ST-04: Xóa lại coupon đã deleted bị từ chối
- ST-05: Coupon active được áp dụng và tăng usage count của user
- ST-06: Dùng quá max_uses_per_user bị từ chối
- ST-07: Coupon expired không được áp dụng
- ST-08: Coupon deleted không được áp dụng

Chi tiết đầy đủ tại [02_state_transitions.json](#).

3.3 Stage 3 - Security - admin-coupons

- **AI Tool:** Codex (GPT-5)
- **Date and Time:** 2026-08-23 02:15:08 +07
- **Your prompt:**

Với FR-17 admin coupon API (`POST /api/admin/coupons` và `DELETE /api/admin/coupons/:id`), rà checklist security SEC-01 đến SEC-07. Bắt buộc test SEC-02 vì admin API yêu cầu JWT hợp lệ và SEC-03 vì admin API phải kiểm role=admin chứ không chỉ kiểm có token. Thêm các case phù hợp: token thiếu/rỗng/sai định dạng/hết hạn, user thường gọi API admin, SQL injection vào `code`, XSS payload trong `code`, mass assignment field ngoài spec, IDOR/scope nếu hệ thống có tenant, và response không lộ field nhạy cảm. Với SEC không áp dụng trực tiếp, ghi rõ trong notes. Trả về JSON array theo `test\_case\_schema.md`, `category=Security`, có `sec\_id` và `attack\_vector`.

- **The AI output:** Đã sinh 11 test case:
 - SEC-01: Gọi API tạo coupon không có Authorization header
 - SEC-02: Authorization header rỗng khi tạo coupon
 - SEC-03: Token sai định dạng khi tạo coupon
 - SEC-04: Token hết hạn khi tạo coupon
 - SEC-05: User thường dùng JWT hợp lệ gọi API admin tạo coupon
 - SEC-06: User thường dùng JWT hợp lệ xóa coupon admin
 - SEC-07: SQL injection payload trong code coupon
 - SEC-08: XSS payload trong code coupon
 - SEC-09: Mass assignment field role và created_by trong body tạo coupon
 - SEC-10: IDOR: Admin của scope khác hoặc token hợp lệ không sở hữu resource thử xóa coupon
 - SEC-11: Response tạo coupon không được lộ thông tin nhạy cảm của admin

Chi tiết đầy đủ tại [03_security.json](#).

3.4 Stage 4 - Schema Validation - admin-coupons

- **AI Tool:** Codex (GPT-5)

- **Date and Time:** 2026-08-23 02:15:58 +07

- **Your prompt:**

Với FR-17 admin coupon API, sinh schema validation test case đối chiếu response với spec: response tạo coupon thành công có đủ field coupon suy ra từ body (`id`, `code`, `type`, `discount\_value`, `min\_order\_amount`, `expired\_at`, `max\_uses\_per\_user`), đúng kiểu dữ liệu, không có field thừa/nhảy cảm; response lỗi validation/401/403/404 là JSON có message hoặc error.message và không trả HTML/stack trace. Bao gồm cả `DELETE /api/admin/coupons/:id` vì spec cùng mục 6.4. Trả về JSON array theo `test\_case\_schema.md`, `category=SchemaValidation`, có `schema\_ref` và `fields\_checked`.

- **The AI output:** Đã sinh 8 test case:
 - SV-01: Response tạo coupon thành công có đủ field coupon bắt buộc
 - SV-02: Kiểu dữ liệu response coupon đúng với spec
 - SV-03: Response tạo coupon không chứa field ngoài schema
 - SV-04: Validation error khi thiếu code có cấu trúc lỗi ổn định
 - SV-05: Unauthorized error khi thiếu token đúng status và schema
 - SV-06: Forbidden error khi user thường gọi API admin đúng status và schema
 - SV-07: Response xóa coupon thành công có schema tối thiểu nhất quán
 - SV-08: Response xóa coupon không tồn tại trả 404 đúng schema lỗi

Chi tiết đầy đủ tại [04_schema_validation.json](#).

4. Các Tương Tác Hỗ Trợ Kỹ Thuật và Báo Cáo (General & Tooling Tasks)

4.1 Sửa Postman collection để tự lấy token đăng nhập

- **AI Tool:** Codex (GPT-5)
- **Date and Time:** 2026-08-23 03:25:03 +07
- **Your prompt:**

Tạo một API login để lấy token sẵn trong Postman collection.

- **The AI output:** Đã cập nhật [API-testing/build_common_postman_collection.js](#) để sinh folder [Auth - Get Tokens](#) ở đầu Postman collection, gồm request login admin lưu [adminToken](#) và request login user lưu [userToken](#) vào collection variables. Đã regenerate [API-testing/eshop_api.postman_collection.json](#) để các request admin coupon dùng token lấy sẵn trong collection.

4.2 Sửa Postman collection để gán mã số sinh viên bằng Pre-request Script

- **AI Tool:** Codex (GPT-5)

- **Date and Time:** 2026-08-23 03:36:59 +07
- **Your prompt:**

Vậy hãy đổi lại sử dụng pre-request script để gán header mã số sinh viên.

- **The AI output:** Đã cập nhật `API-testing/build_common_postman_collection.js` để thêm collection-level Pre-request Script tự lấy `studentId` từ biến Postman và upsert header `X-Student-Id` trước mỗi request. Đã bỏ header `X-Student-Id` hard-code khỏi từng request, regenerate `API-testing/eshop_api.postman_collection.json`, và sửa workflow để Newman dùng environment file thay vì truyền `studentId` qua CLI.

4.3 Thêm data-driven run cho Postman collection

- **AI Tool:** Codex (GPT-5)
- **Date and Time:** 2026-08-23 03:42:26 +07
- **Your prompt:**

Vậy hãy thêm data-driven cho collection này đi.

- **The AI output:** Đã thêm request data-driven DP-DD - Áp dụng coupon bằng iteration data vào đúng suite `FR-09 Apply Coupon > domain partitions`, dùng biến từ iteration data (`couponCode`, `totalAmount`, `userId`, `expectedStatus`, `expectedHasDiscount`). Đã tạo file `API-testing/data/apply_coupon_data.csv` gồm các dòng dữ liệu positive/negative cho apply-coupon, regenerate `API-testing/eshop_api.postman_collection.json`, và cập nhật `API-testing/README.md`.

4.4 Tách Postman collection theo từng API

- **AI Tool:** Codex (GPT-5)
- **Date and Time:** 2026-08-23 04:12:06 +07
- **Your prompt:**

Tôi muốn tách ra 3 collection riêng ứng với 3 API để dễ quản lý.

- **The AI output:** Đã cập nhật `API-testing/build_common_postman_collection.js` để ngoài collection tổng `eshop_api.postman_collection.json` còn sinh thêm 3 collection riêng: `forgot_password.postman_collection.json`, `apply_coupon.postman_collection.json`, và `admin_coupons.postman_collection.json`. Đã cập nhật GitHub Actions workflow để chạy 3 collection riêng và upload các report HTML theo glob `API-testing/newman-*-report.html`; đồng thời cập nhật `API-testing/README.md` với lệnh Newman cho từng collection.

4.5 Refactor apply-coupon collection sang data-driven

- **AI Tool:** Codex (GPT-5)

- **Date and Time:** 2026-08-23 18:15:00 +07
- **Your prompt:**

bạn hãy refactor file collection apply_coupon thử đi

- **The AI output:** Đã refactor `API-testing/apply_coupon.postman_collection.json` thành collection data-driven một request, chạy 49 test case qua `data/apply-coupon.test-data.json`, gồm 42 case AI-generated và 7 case human-extended `HT-APPLY-EXT-001..007`. Mỗi row dùng `testCaseId` để trace test case và field `assertions` để bật các assert sâu riêng như SQL leak, XSS echo, công thức `final_amount`, exact calculation, money bounds, preview no-side-effect, và chống client tự gửi `discount_amount/final_amount`. Đã thêm `API-testing/build_apply_coupon_data_driven_collection.js`, cập nhật `npm run apply`, và sửa README command tương ứng.

4.6 Chuẩn hóa expectedStatus của apply-coupon theo CSV review

- **AI Tool:** Codex (GPT-5)
- **Date and Time:** 2026-08-23 18:56:00 +07
- **Your prompt:**

hiện file data có một số chỗ response code đang bị mơ hồ kìa hãy viết lại chuẩn theo file csv đi

- **The AI output:** Đã cập nhật builder `API-testing/build_apply_coupon_data_driven_collection.js` để đọc `API-testing/apply-coupon/test_cases_master.csv` và đồng bộ `expectedStatus/expectedResult` cho 49 row trong `data/apply-coupon.test-data.json`. Các status mơ hồ như `400` hoặc `404`, `200` hoặc `400`, `429` sau `N...` đã được thay bằng mã cụ thể theo CSV; case BLOCKED giữ `N/A`. Đồng thời chỉnh một số request body đã được CSV audit chốt theo seed data như `EXPIRED`, `SAVE10` boundary, và public apply-coupon auth cases.

4.7 Đối chiếu apply-coupon report với CSV và bug reports

- **AI Tool:** Codex (GPT-5)
- **Date and Time:** 2026-08-23 19:07:00 +07
- **Your prompt:**

Hãy so sánh kết quả của file `apply-coupon-report-1.html` với kết quả trong file `apply-coupon/test-case-master.csv` để xem có chỗ nào lệch không, nếu có thì sửa theo file html report. Sau đó đối chiếu các bug report và thống kê cho tôi những chỗ lệch đã sửa

- **The AI output:** Đã thêm script đối chiếu `API-testing/sync_apply_coupon_csv_with_report.js`, parse `API-testing/apply-coupon-report-1.html`, cập nhật `API-testing/apply-`

`coupon/test_cases_master.csv` theo kết quả report, và đối chiếu các bug report `BUG-APPLY-COUPON-*.md`. Kết quả sửa chính: `TC-APPLY-COUPON-SEC-009` đổi `Status` từ `PASS` sang `FAIL`; bug tương ứng đã được bao phủ bởi `BUG-APPLY-COUPON-001-negative-discount-calculation.md`. Đồng thời quote lại field `Notes` của `HT-APPLY-EXT-007` vì có dấu phẩy để CSV không bị lệch cột.

4.8 Sửa apply-coupon test cases dùng coupon ngoài seed data

- **AI Tool:** Codex (GPT-5)
- **Date and Time:** 2026-08-23 19:17:00 +07
- **Your prompt:**

Hiện tại trong file csv có một số cái incomplete và invalid bởi vì khi test thì nó apply coupon không tồn tại trong seed data vì vậy bạn hãy sửa những chỗ mà apply coupon không tồn tại đó thành coupon tồn tại. Bạn hãy đọc file `README.md` ở thư mục root để biết rõ đặc tả hệ thống.

- **The AI output:** Đã đọc root `README.md` và xác nhận coupon seed hợp lệ cho FR-09 là `SAVE10`, `BIGBUY`, `VIP100`, `EXPIRED`. Đã cập nhật `API-testing/apply-coupon/test_cases_master.csv`, `API-testing/data/apply-coupon.test-data.json`, và regenerate `API-testing/apply_coupon.postman_collection.json` để thay các case từng dùng coupon ngoài seed bằng coupon seed tương ứng. Các case state transition hết hạn/xóa/flash sale dùng `EXPIRED`; các case min-order/quota/parameter tampering/auth dùng `SAVE10`. Đồng thời sửa lại auth cases theo `README.md` vì FR-09 yêu cầu JWT hợp lệ.

4.9 Đồng bộ Status CSV apply-coupon theo report mới

- **AI Tool:** Codex (GPT-5)
- **Date and Time:** 2026-08-23 19:23:00 +07
- **Your prompt:**

Đọc file `apply-coupon-report.html` vừa chạy và kiểm tra xem file csv có chỗ nào bị lệch status không nếu có thì đổi theo html và thống kê cho tôi biết

- **The AI output:** Đã cập nhật `API-testing/sync_apply_coupon_csv_with_report.js` để nhận tên report qua CLI và giữ các case `BLOCKED/expected_status=N/A` ở trạng thái blocked. Đã chạy đối chiếu `API-testing/apply-coupon-report.html` với `API-testing/apply-coupon/test_cases_master.csv`: report có 49 test cases, 31 failed, 1 skipped/blocked. Có 1 lệch status đã sửa: `TC-APPLY-COUPON-ST-008` đổi từ `FAIL` sang `PASS`; chạy lại script xác nhận không còn lệch status.

4.10 Thêm auto-login lấy userToken cho apply-coupon collection

- **AI Tool:** Codex (GPT-5)
- **Date and Time:** 2026-08-23 19:35:00 +07
- **Your prompt:**

oke làm vậy đi

- **The AI output:** Đã cập nhật `API-testing/build_apply_coupon_data_driven_collection.js` để pre-request script tự gọi `POST /api/login` bằng seed user `test@eshop.com / Test1234!` khi iteration row dùng `authorization: "Bearer {{userToken}}"` và chưa có `userToken`. Token được lưu vào collection variable rồi gắn vào header `Authorization`; các row có `authorization` rỗng vẫn chạy không token để giữ no-auth/security cases. Đã regenerate `API-testing/apply_coupon.postman_collection.json`, giữ 49 rows trong `API-testing/data/apply-coupon.test-data.json`, cập nhật `API-testing/README.md`, và chạy `npm run apply` xác nhận auto-login hoạt động trong Newman report.

4.11 Đối chiếu bug reports apply-coupon với danh sách test case

- **AI Tool:** Codex (GPT-5)
- **Date and Time:** 2026-08-23 19:39:00 +07
- **Your prompt:**

check lại các bug report coi có khớp với danh sách test case không

- **The AI output:** Đã thêm script `API-testing/check_apply_coupon_bug_coverage.js` để parse `API-testing/Bug/BUG-APPLY-COUPON-*.md`, `API-testing/apply-coupon/test_cases_master.csv`, và `API-testing/apply-coupon-report.html`. Lần kiểm đầu phát hiện không có ID lạ và không có bug nào trở tới PASS/BLOCKED, nhưng còn 5 failed test cases chưa được bug report cover. Đã bổ sung `TC-APPLY-COUPON-DP-016`, `TC-APPLY-COUPON-SEC-009`, `HT-APPLY-EXT-006` vào bug 001 và tạo `BUG-APPLY-COUPON-008-missing-auth-and-user-binding.md` cho `TC-APPLY-COUPON-SEC-003`, `TC-APPLY-COUPON-SEC-004`. Chạy lại checker xác nhận 31 failed test cases đều được cover bởi 8 bug reports, không còn lệch.

4.12 Refactor forgot-password collection sang data-driven

- **AI Tool:** Codex (GPT-5)
- **Date and Time:** 2026-08-23 19:46:00 +07
- **Your prompt:**

Hãy refactor lại collection forgot-password giống với collection apply-coupon. Cũng xem file forgot-password/test-case-master.csv làm chuẩn.

- **The AI output:** Đã refactor `API-testing/forgot_password.postman_collection.json` thành collection data-driven một request template, sinh từ `API-testing/forgot-password/test_cases_master.csv` qua `API-testing/build_forgot_password_data_driven_collection.js`. Đã tạo `API-testing/data/forgot-password.test-data.json` gồm 45 rows, mỗi row có `testCaseId`, `method/path/body`, `expectedStatus`, `setupFlow`, và `assertions` riêng cho OTP format, schema, user

enumeration, cache header, GET method confusion, reset-password state flows, OTP reuse, OTP binding, và weak password. Đã cập nhật `npm run forgot` và README để chạy với `--iteration-data`. Chạy `npm run forgot` xác nhận collection mới chạy đủ 45 iterations / 67 requests / 201 assertions; còn 25 failures phản ánh behavior lệch CSV/spec. Đã restore seed password `test@eshop.com` về `Test1234!` sau khi chạy.

4.13 Chuẩn hóa format data-driven forgot-password và apply-coupon

- **AI Tool:** Codex (GPT-5)
- **Date and Time:** 2026-08-23 20:15:00 +07
- **Your prompt:**

sao file data của forgot-password có 2 cái không cần là "reviewStatus": "PASS", và "notes": vậy hãy làm file data giữa forgot-password và apply-coupon đồng nhất với nhau đi. Những cái nào cần thiết thì giữ và thống nhất format

- **The AI output:** Đã cập nhật `API-testing/build_forgot_password_data_driven_collection.js` để file runtime `API-testing/data/forgot-password.test-data.json` chỉ xuất các field cần cho data-driven Newman giống `apply-coupon`: `testCaseId`, `metadata request`, `expectedStatus`, `expectedResult`, `secId`, `attackVector`, và `assertions`; giữ riêng `setupFlow` vì forgot-password cần chuẩn bị OTP/reset-password theo từng case. Đã loại các field audit/review như `reviewStatus`, `validationStatus`, `notes` khỏi JSON runtime, normalize `expectedStatus` về number khi là HTTP code, regenerate `API-testing/data/forgot-password.test-data.json` và `API-testing/forgot_password.postman_collection.json`, đồng thời sửa extract `secId` để đọc đúng `SEC-01..SEC-07` từ CSV master.

4.14 Tạo collection data-driven cho admin-coupons

- **AI Tool:** Codex (GPT-5)
- **Date and Time:** 2026-08-23 21:25:00 +07
- **Your prompt:**

Hãy tạo file collection cho admin-coupons. Đọc file `test_cases_master.csv` để hiểu các test cases. Xem format của các file data của 2 api khác. Vì luồng này cần token để test nên nhớ setup để lấy token.

- **The AI output:** Đã tạo collection data-driven `API-testing/admin_coupons.postman_collection.json` cho `POST /api/admin/coupons`, sinh từ `API-testing/admin-coupons/test_cases_master.csv` qua script `API-testing/build_admin_coupons_data_driven_collection.js`. Đã tạo `API-testing/data/admin-coupons.test-data.json` đủ 49 rows, đồng nhất format runtime với `apply-coupon` và `forgot-password`, không đưa các field audit như `sourceFile`, `priority`, `reviewStatus`, `notes`, `Audit`, `Status` vào data JSON. Collection có pre-request script tự login admin/user qua `POST /api/login`, lưu `adminToken` và `userToken`, đồng thời sinh token hết hạn và forged token cho security cases. Các case

ngoài scope được set skipped để Newman report hiện **skipped** thay vì fail; đã thêm script `npm run admin` trong `API-testing/package.json`.

4.15 Sửa CI workflow chạy ba Postman collections

- **AI Tool:** Codex (GPT-5)
- **Date and Time:** 2026-08-23 22:35:00 +07
- **Your prompt:**

Hãy sửa CI workflow để chạy 3 file collection đi

- **The AI output:** Đã cập nhật `.github/workflows/api-tests.yml` để CI cài dependency cho `API-testing`, chạy lần lượt ba script Newman `npm run forgot`, `npm run apply`, `npm run admin`, gom exit code để cả ba collection đều chạy trước khi job fail nếu có lỗi. Đã bỏ bước build/run collection cũ `eshop_data_driven.postman_collection.json` và đổi artifact upload sang ba report HTML: `forgot-password--report.html`, `apply-coupon-report.html`, `admin-coupons-report.html`.

4.16 Viết main report Sections 1-5

- **AI Tool:** Codex (GPT-5)
- **Date and Time:** 2026-08-23 22:55:00 +07
- **Your prompt:**

Hãy đọc file `main-report.md` và viết dựa trên các artifact hiện có trong folder `API-testing`

- **The AI output:** Đã viết lại `API-testing/report/main-report.md` theo template Sections 1-5 dựa trên artifact thật trong `API-testing`: README, ba `test_cases_master.csv`, ba collection Postman, ba data JSON, ba Newman HTML reports, bug reports, audit logs, và CI workflow. Report hiện có thông tin SUT, API selection, tổng quan từng API, số lượng AI-generated/audit/human-added/executed/pass/fail/blocked/not-executed, danh sách bug reports, Postman features, CI/CD pipeline, và thiết kế AI-driven API test generator. Các thông tin cá nhân/CI run link không có trong artifact được ghi rõ là chưa có evidence thay vì bịa.